ĐỒ ÁN LẬP TRÌNH WEB VÀ ỨNG DỤNG

What2Eat

Website khám phá quán ăn và hỗ trợ
ghi chép nhật ký ẩm thực cá nhân

THÀNH VIÊN THỰC HIỆN
TĂNG DUY VIỆT — 52400255
LƯU NHẬT QUANG — 52400229

GIẢNG VIÊN HƯỚNG DẪN
ThS. Doãn Xuân Thanh

TRƯỜNG ĐẠI HỌC TÔN ĐỨC THẮNG · KHOA CÔNG NGHỆ THÔNG TIN
TP. Hồ Chí Minh — 2026

Bài toán & phạm vi

Một câu hỏi thường ngày — lời giải bằng dữ liệu mở và ghi chép cá nhân.

Vấn đề thực tế

Thông tin quán ăn phân tán: OSM thiếu tiếng Việt, bài đánh giá lẫn quảng cáo.
Trải nghiệm ăn uống trôi qua, không lưu lại được để lần sau chọn tiếp.
Nhóm bạn mất nhiều vòng nhắn tin mới chốt được một quán.

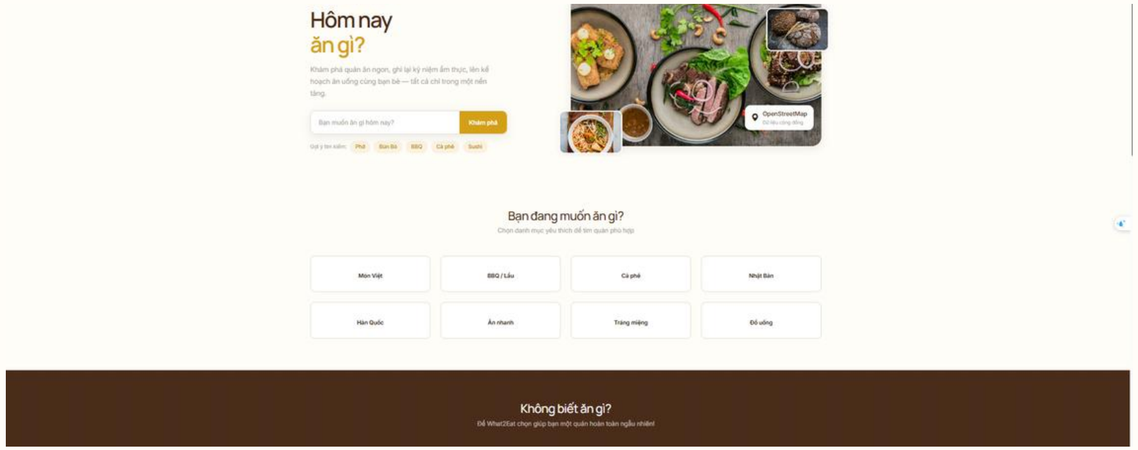
Phạm vi đồ án

Khám phá: quán quanh vị trí, bản đồ và bộ lọc OpenStreetMap.
Food Note: nhật ký ẩm thực cá nhân, chia sẻ có kiểm soát.
Food Plan: cùng đề xuất quán và bỏ phiếu chốt kế hoạch.
Quản trị: duyệt nội dung, xác minh và ẩn địa điểm sai.

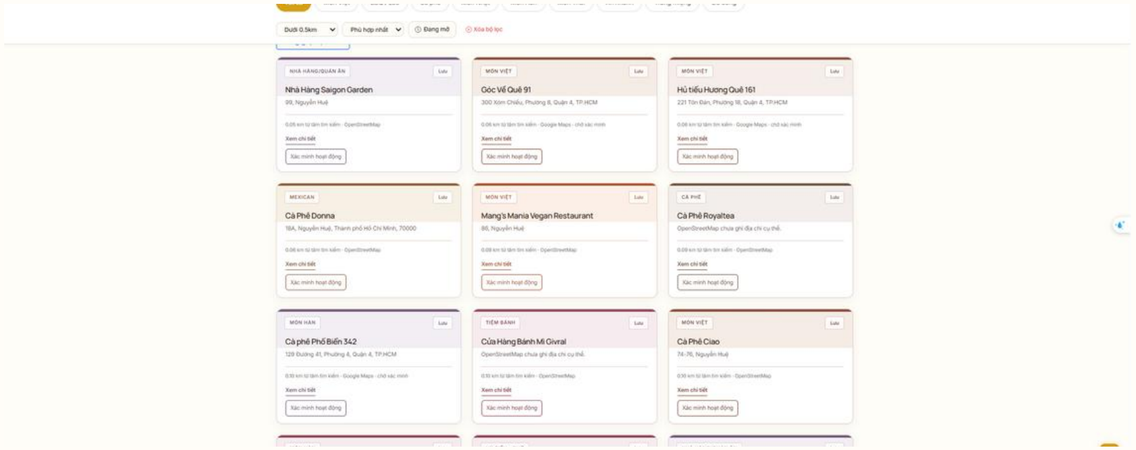
Ngoài phạm vi: đặt món, thanh toán, giao hàng — đồ án tập trung vào khám phá và ghi chép.

Sản phẩm

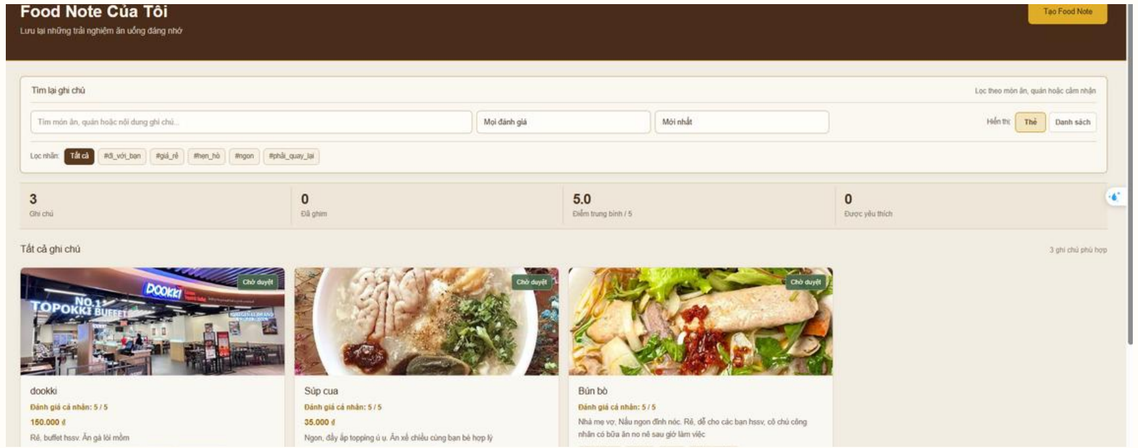
Bốn màn hình chính — cả hệ thống sẽ được demo trực tiếp ngay sau phần trình bày.



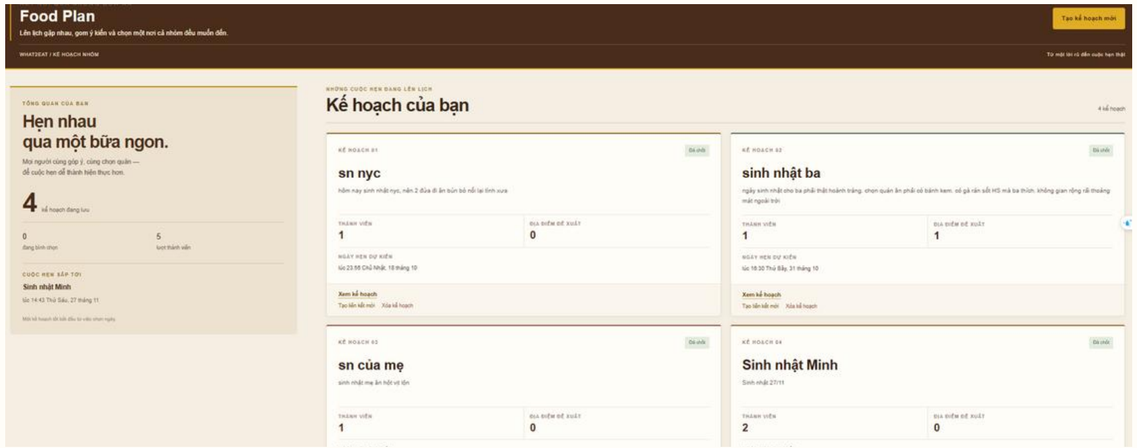
Trang chủ



Khám phá — danh sách quét quanh vị trí



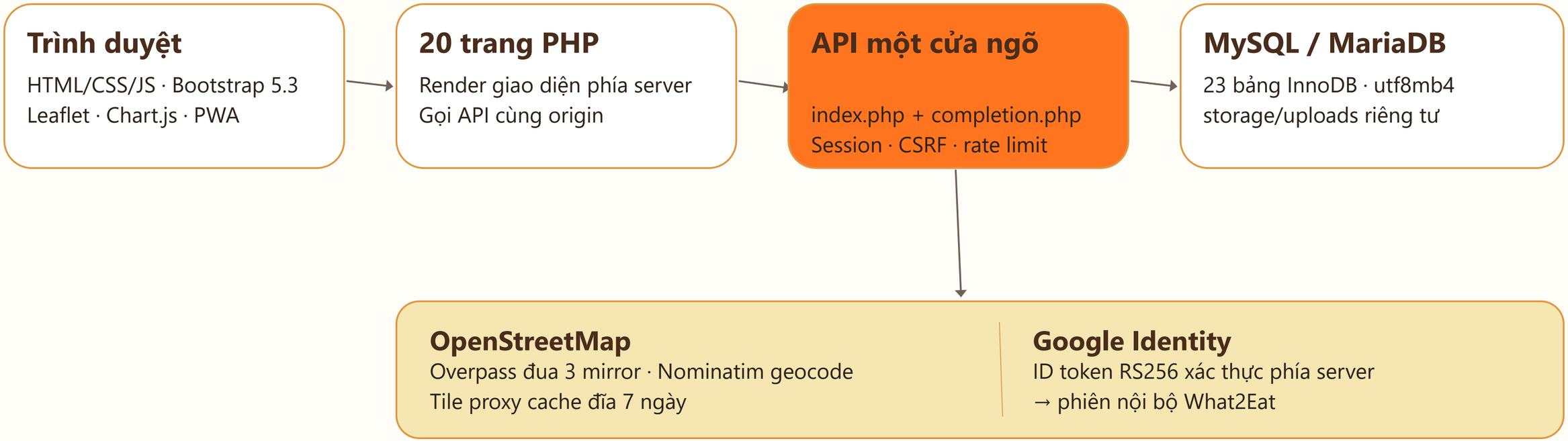
Food Note — nhật ký ẩm thực cá nhân



Food Plan — kế hoạch ăn chung của nhóm

Kiến trúc tổng thể

Trình duyệt không chạm thẳng cơ sở dữ liệu — mọi thứ đi qua một API cùng origin.



Không framework PHP: router tự viết nên chạy được shared hosting; Node.js chỉ xuất hiện trong bộ kiểm thử.

Công nghệ được chọn

Mỗi lựa chọn đều đánh đổi có chủ đích: nhẹ, dễ triển khai, đủ chắc cho đồ án.

PHP 8.1+ thuần & PDO

Router tự viết, không cần build step; prepared statements thật (tắt emulate) chống SQL injection; chạy được mọi shared hosting.

MySQL 8 / MariaDB InnoDB

Transaction và khóa hàng cho vote, plan; utf8mb4 giữ tiếng Việt; CHECK và khóa ngoại giữ toàn vẹn dữ liệu.

Vanilla JS + Bootstrap 5.3

Không SPA phức tạp; Leaflet 1.9.4 cho bản đồ, Chart.js 4 cho thống kê; tải nhanh trên máy yếu và mạng chậm.

PHPMailer 7 · PWA · Node

Mail xác minh và khôi phục mật khẩu; service worker cache vỏ ứng dụng; Node.js chỉ chạy bộ kiểm thử.

Vòng đời một request API

Bảy bước cố định cho mọi request — từ định tuyến tới ghi vết kiểm toán.

1. **Định tuyến** — Khớp method + path trong router tập trung
2. **Bootstrap** — Session, CSRF, header bảo mật, rate limit
3. **Phân quyền** — Guest / user / admin theo phiên
4. **Validate** — Kiểu, biên, độ dài trước khi chạm DB
5. **Truy vấn** — PDO prepared; transaction khi ghi nhiều bảng
6. **Phản hồi** — JSON nhất quán, mã lỗi HTTP đúng nghĩa
7. **Audit** — Ghi vết hành động nhạy cảm vào audit_logs

Một cửa ngõ duy nhất: chính sách bảo mật và ghi vết chỉ phải cài đặt một lần.

Cơ sở dữ liệu

Schema là tầng bảo vệ cuối cùng: dù code sót, ràng buộc vẫn giữ dữ liệu đúng.

23
bảng InnoDB trong schema

8
bản migration được ghi vết

utf8mb4
unicode_ci — tiếng Việt không mất dấu

Toàn vẹn từ ràng buộc

CHECK rating 0–5 và giá ≥ 0; khóa ngoại giữ quan hệ note – media – quán không mồ côi.

Chống trùng từ schema

Khóa kép (proposal_id, user_id): mỗi người chỉ một vote trong một plan; DB tự chặn bản ghi thứ hai.

Vận hành nằm trong DB

api_cache giữ phản hồi OSM và geocode; audit_logs ghi vết; schema_migrations theo dõi phiên bản.

Xác thực & phiên

Hai lớp: phiên đúng chủ sở hữu, và chặn giả mạo từ bên ngoài.

Mật khẩu & phiên

Argon2id cho mật khẩu; tự rehash khi đăng nhập nếu thuật toán cũ hơn.
session_regenerate_id(true) chống cố định phiên sau đăng nhập.
session_version tăng khi đổi mật khẩu: mọi phiên cũ hết hiệu lực.
Cookie phiên HttpOnly, SameSite=Lax.

Chống giả mạo & dò quét

CSRF token 32 byte, so khớp hash_equals kèm kiểm tra Origin.
Rate limit theo IP bằng khóa HMAC-SHA256, cửa sổ cố định.
Token reset và chia sẻ chỉ lưu dạng băm SHA-256, dùng một lần.

Đổi mật khẩu thu hồi mọi phiên đang đăng nhập — kể cả trên thiết bị khác.

Google Sign-In: xác thực phía máy chủ

Không Client Secret, không redirect URI: trình duyệt nhận ID token, server tự kiểm chữ ký.

Google GIS
Trả ID token (JWT) cho trình duyệt sau khi chọn tài khoản

→

POST /auth/google
Token gửi cùng origin; không redirect URI, không Client Secret

→

Verify RS256
JWKS cache · dựng khóa RSA từ JWK · openssl_verify

→

Phiên nội bộ
Đối chiếu sub → tạo hoặc đăng nhập tài khoản What2Eat

Claim bắt buộc trước khi tạo phiên

aud/azp đúng client ID · iss = accounts.google.com · exp chưa hết hạn · iat không từ tương lai · email_verified = true · sub ổn định làm khóa tài khoản.

Trạng thái hiện tại: OAuth External/Testing, client chỉ đăng ký origin localhost. Bản public cần Web client riêng, branding và publish theo DEPLOYMENT.md — không mang client dev lên production.

OSM: năm lớp dự phòng

Thứ tự trong mã nguồn: snapshot trước tiên — Overpass chỉ dùng ngoài vùng phủ hoặc khi cần làm mới.

Snapshot cục bộ	Cache tươi	Đua 3 Overpass	Cache cũ ≤ 24h	Snapshot / 502
8.600 quán HCMC phủ sẵn — trả ngay, không gọi remote	api_cache còn hạn ≤ 10 phút thì dùng lại	curl_multi gọi 3 mirror; phản hồi tốt đầu tiên thắng	Cả 3 mirror chết: dùng cache hết hạn nhưng chưa quá một ngày	Quét lại snapshot lần cuối; hết cách mới trả lỗi 502

Truy vấn có kỷ luật

Overpass QL: timeout 12s, out center 250; loại tag disused / abandoned / demolished để không hiện quán đã đóng.

Tile bản đồ qua proxy

Server tải tile từ hai nguồn, cache đĩa 7 ngày; nguồn chết vẫn còn tile cũ thay vì bản đồ trắng.

Không gian & tiếng Việt

Hai bài toán đặc thù: khoảng cách thật trên bản đồ và tìm kiếm không dấu.

KHOẢNG CÁCH THẬT

Haversine theo vĩ độ / kinh độ
Lọc bán kính trước khi xếp hạng
Index vùng để giảm tập ứng viên

TÌM KIẾM KHÔNG DẤU

Chuẩn hóa Unicode
Lowercase + bỏ dấu
So khớp tên và địa chỉ

“com que” → “Cơm quê”

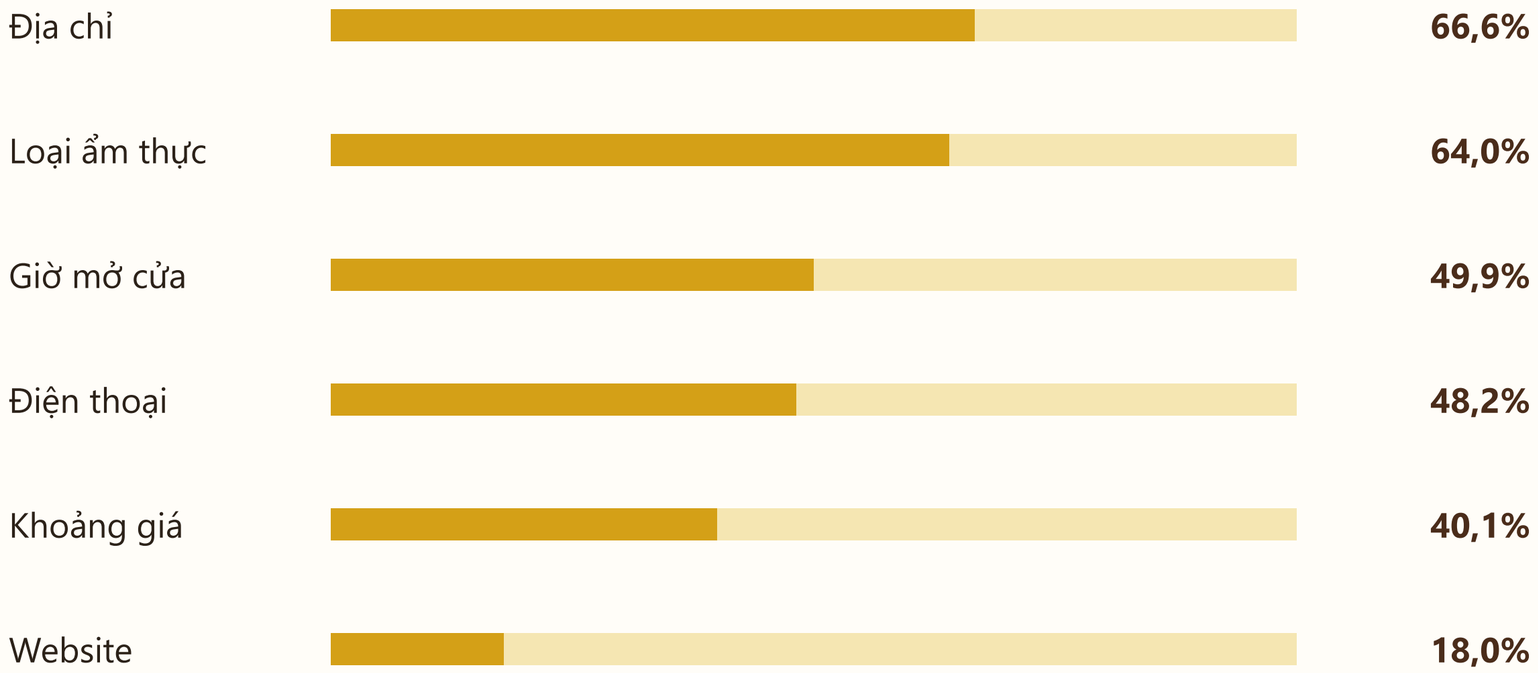
Chất lượng dữ liệu snapshot

Tỷ lệ trường có giá trị trong snapshot — đo trực tiếp trên dữ liệu đã nhập.

8.600

quán ăn trong snapshot OSM khu vực TP.HCM

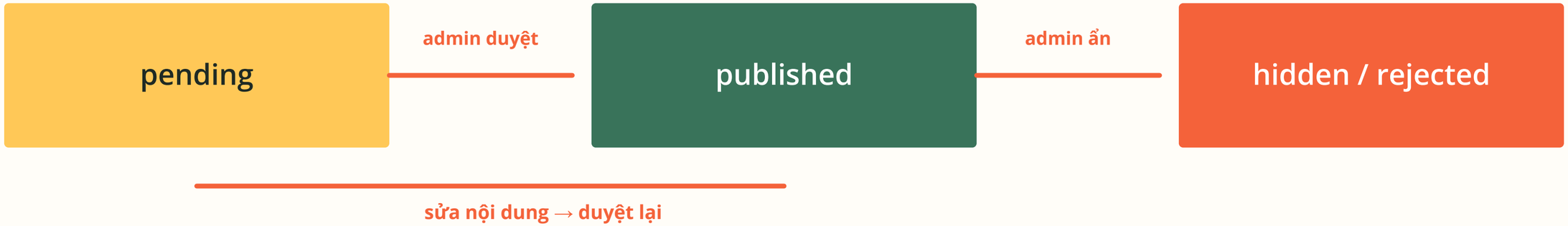
Snapshot đóng băng từ dữ liệu cộng đồng, nhập bằng import-catalog; là lớp dự phòng cuối cùng của khám phá.



Trường còn thiếu được cộng đồng bổ sung qua place-corrections (admin duyệt) và xác minh trạng thái hoạt động của quán.

Food Note: máy trạng thái

Nội dung cộng đồng chỉ hiển thị khi qua duyệt; sửa là phải duyệt lại.



KHÓA · Riêng tư

KHÓA · Bạn bè

KHÓA · Công khai

private — chỉ chủ ghi chú xem được.
public — cộng đồng xem sau khi admin duyệt.
link — ai giữ liên kết xem được; token băm SHA-256, xoay hoặc thu hồi bất cứ lúc nào.

Ghim và yêu thích là cờ độc lập — không kéo ghi chú đã duyệt về hàng chờ.

Food Plan: cộng tác nhất quán

Nhiều người cùng sửa một kế hoạch — transaction và khóa hàng giữ kết quả nhất quán.

Chống race condition

TRANSACTION

Gom nhiều thay đổi thành một đơn vị
Tất cả thành công — hoặc rollback
Không để kế hoạch ở trạng thái dở dang

Một người — một vote

KHÓA HÀNG

SELECT … FOR UPDATE
Tuần tự hóa thay đổi cạnh tranh
Kiểm phiên bản trước khi ghi

Invite xoay vòng: token chỉ lưu dạng băm trong DB; xoay token mới thì mọi liên kết cũ hết hiệu lực ngay lập tức.

Upload & riêng tư media

Ba cửa ải cho mỗi tệp: nội dung thật, đường dẫn ngẫu nhiên, phục vụ có kiểm quyền.

Kiểm tra nội dung thật

finfo đọc MIME thực của tệp, không tin đuôi file hay Content-Type gửi lên.
Chỉ nhận JPEG, PNG, WEBP, GIF, MP4, WEBM; sai trả 415.

Không đoán được đường dẫn

Tên 48 ký tự hex ngẫu nhiên + đuôi đúng MIME thật.
realpath chắn traversal; vùng storage cấm thực thi.

Xem qua cửa kiểm quyền

Media đi qua endpoint API: note private chỉ chủ xem được.
nosniff + Cache-Control private; xóa note là xóa tệp.

Tệp không nằm trong web root công cộng: không thể đoán URL để xem trộm ảnh riêng tư.

PWA & hiệu năng

Offline có kỷ luật và cache nhiều tầng để không phụ thuộc mạng ngoài.

Service worker kỷ luật

PWA CÓ KỶ LUẬT

11 tài nguyên lõi precache
7 ngày cho static assets
Offline shell chỉ cho màn hình an toàn

Loại trừ /api, /admin, /storage, /includes, /tiles — không cache dữ liệu nhạy cảm.
Navigate network-first; mất mạng rơi về offline.html.
Cache đổi tên theo phiên bản — không kẹt bản cũ.

Giảm tải đường dài

CACHE NHIỀU TẦNG

10 phút cho truy vấn nóng
30 ngày cho dữ liệu ít đổi
8.600 địa điểm không tải lại vô ích

Tile bản đồ cache đĩa 7 ngày, hai nguồn dự phòng nhau.
api_cache: OSM 10 phút, geocode 30 ngày.
Snapshot 8.600 quán trả ngay không gọi remote.
session_write_close trước khi stream tile và ảnh.

Vận hành & triển khai

Từ schema tới hosting: mọi bước đều có script hoặc checklist lặp lại được.

migrate.php

Schema + ALTER idempotent; ghi vết vào schema_migrations

CLI tiện ích

create-admin, import-catalog chạy bằng PHP CLI

Hosting

InfinityFree · what2eat.click · HTTPS; .env giữ bí mật

Checklist

DEPLOYMENT.md: OAuth, mail, branding trước khi public

Tách môi trường rõ ràng

Client Google dev chỉ cho localhost; production cần client riêng, mail sender thật, và trang chính sách điền đúng vận hành thực tế trước khi publish.

Mục tiêu: người khác có thể triển khai lại mà không cần “nhớ thao tác”.

Kiểm thử

Không mock tràn lan: bộ tích hợp dựng một hệ thống thu nhỏ rồi dọn sạch sau khi chạy.

4
file kiểm thử trong thư mục tests/

12
nhóm hành vi được phủ tích hợp

1
lệnh chạy cả bộ tích hợp

INTEGRATION TEST CHẠY NHƯ HỆ THỐNG THẬT

Tạo schema tạm · Seed dữ liệu nhỏ · Gọi API thật · Dọn sạch sau chạy

Frontend chưa có kiểm thử tự động — đã ghi nhận trong hướng phát triển.

Điểm mạnh & đánh đổi

Nhóm nhìn thẳng vào phần chưa làm được — đó là đầu vào của hướng phát triển.

ĐIỂM MẠNH ✓

Kiến trúc một cửa ngõ rõ ràng
Ràng buộc dữ liệu nhiều lớp
Có chiến lược offline và fallback
Quyền riêng tư đi từ thiết kế

ĐÁNH ĐỔI CHẤP NHẬN !

Snapshot cần làm mới định kỳ
PHP thuần cần kỷ luật cấu trúc
Chưa tối ưu cho quy mô rất lớn
UX cộng tác còn cơ bản

Đánh đổi có ý thức: kịp phạm vi đồ án, giữ hệ thống nhẹ và dễ triển khai trên hosting thật.

Hạn chế & hướng phát triển

Bốn hướng ưu tiên — đều xuất phát từ hạn chế đã tự nhận ở trang trước.

Bảo mật chiều sâu	Thêm Content-Security-Policy, 2FA và rate limit sliding window thay cửa sổ cố định.
Kiểm thử frontend	Playwright cho các luồng chính trên trình duyệt thật, chạy cùng bộ tích hợp hiện có.
Dữ liệu & thống kê	Nối dashboard vào số liệu thật; mở rộng snapshot ra ngoài TP.HCM.
Production hóa	OAuth client riêng cho domain thật, publish Google app, mail sender và chính sách vận hành thật.

Kịch bản demo trực tiếp

Ba kịch bản nối nhau đi hết bốn trụ cột của hệ thống.

1

Khám phá

Quét quán quanh vị trí → lọc theo món và bán kính → xem chi tiết → bổ sung hoặc báo sai thông tin.

2

Food Note

Tạo ghi chú kèm ảnh → admin duyệt → chia sẻ liên kết công khai rồi thu hồi ngay trên giao diện.

3

Food Plan

Mời thành viên bằng liên kết → cùng đề xuất quán → bỏ phiếu → chốt kế hoạch của nhóm.

Demo chạy trên bản triển khai thật: mọi thao tác đều đi qua đúng API, ràng buộc và hàng chờ duyệt đã trình bày.

Cảm ơn thầy cô và các bạn

What2Eat — Hôm nay ăn gì?

Tăng Duy Việt · 52400255
Lưu Nhật Quang · 52400229

TRƯỜNG ĐẠI HỌC TÔN ĐỨC THẮNG · KHOA CÔNG NGHỆ THÔNG TIN · 2026